

Lista de verificación de controles y cumplimiento

Para completar la lista de verificación de evaluación de controles, consulte la información proporcionada en el informe de alcance, objetivos y evaluación de riesgos. Para obtener más detalles sobre cada control, incluido el tipo y el propósito, consulte el documento de categorías de control.

Luego, seleccione “sí” o “no” para responder la pregunta: ¿Botium Toys cuenta actualmente con este control?

Lista de verificación de evaluación de controles

Si	No	Observaciones(*)
	Menos Privilegio	Actualmente todos los empleados tienen acceso a todos los datos de la empresa .Es una buena práctica, administrarlos en base a la información que uno necesite fundamentalmente para realizar su trabajo.
	Planes de Recuperación ante Desastres	No tienen plan en caso de desastres. Necesitan implementarlos para garantizar la continuidad del negocio.
	Políticas de Contraseña	La contraseña de los usuarios tienen los mínimos requerimientos de seguridad, lo que lo hace vulnerable a posibles ataques.
	Separación de Funciones	Se necesita implementar para que no todos tengan acceso a información sensible.

- Firewall/Cortafuegos
El firewall que tienen bloquea el tráfico de acuerdo a reglas de seguridad apropiadas.

- Sistema de Detección de Intrusiones(IDS)
El departamento IT necesita implementarlo para que los ayude a buscar posibles intrusiones.

- Copias de Seguridad
El departamento IT necesita implementarlas para que en caso de algún inconveniente , se pueda mantener la continuidad del proceso.

- Programa Antivirus
El Antivirus está instalado y monitorizado regularmente por el departamento.

- Monitoreo, mantenimiento e intervención manual para sistemas heredados

La lista de activos indica el uso de sistemas heredados. La evaluación de riesgos indica que estos sistemas son monitoreados y mantenidos, pero no hay un cronograma regular para esta tarea y los procedimientos o políticas relacionados con la intervención no son claros, lo que puede provocar distintos tipos de fallas.

- Encriptacion
No la están usando actualmente. Implementarla aumentaría la confidencialidad de los datos y su seguridad.

- Sistema de Gestión de Contraseñas
Este control no está implementado. Se necesita implementar

en caso de que algún usuario tenga problemas con la contraseña.

- Cerraduras (oficinas, escaparates, almacenes)
La localización física que incluye oficinas, almacenes y escaparates poseen suficientes cerraduras.
- Vigilancia por circuito cerrado de televisión (CCTV)
Esta instalado e implementado correctamente en la localización física .
- Detección/prevención de incendios (alarma contra incendios, sistema de rociadores, etc.)
Está instalado y funcionando en su localización física.

Lista de cumplimiento

Estándar de seguridad de datos de la industria de tarjetas de pago (PCI DSS)

		Mejores prácticas(.)	Observaciones(*)
Si	No		
		• (.)Sólo los usuarios autorizados tienen acceso a la información de las tarjetas de crédito de los clientes. * Actualmente todos los empleados tienen acceso a la información interna. • (.)La información de las tarjetas de crédito se almacena, acepta, procesa y transmite internamente, en un entorno seguro. * La información no de las tarjetas no se encripta lo que es un enorme riesgo y además todos los empleados tienen acceso a la información interna incluida la de las tarjetas.	

- (.)Implementar procedimientos de cifrado de datos para proteger mejor los puntos de contacto y los datos de las transacciones con tarjetas de crédito.
* **La empresa no utiliza sistemas de cifrado lo que es un riesgo enorme a los confidencialidad de la información de los clientes.**
- (.)Adoptar políticas de gestión de contraseñas seguras.
* **No posee ni políticas ni gestión de contraseñas.**

Reglamento General de Protección de Datos (RGPD)

Si	No	Mejores prácticas(.)	Observaciones(*)
	•	(.)Los datos de los clientes de la UE se mantienen privados y seguros.	* Al no tener encriptación, la información financiera de los clientes puede sufrir intentos de robo de forma mucho más sencilla.
•		(.)Hay un plan establecido para notificar a los clientes de la UE dentro de las 72 horas si sus datos se ven comprometidos o se produce una violación.	* Hay un plan para notificar a los clientes de la UE dentro de las 72 horas posteriores a una violación de datos.
	•	(.)Asegúrese de que los datos estén correctamente clasificados e inventariados.	* Si bien tienen listados de objetos estos no están clasificados.
•		(.)Hacer cumplir las políticas, procedimientos y procesos de privacidad para documentar y mantener adecuadamente los datos.	* Se han desarrollado políticas, procedimientos y procesos de

privacidad y se han aplicado entre los miembros del equipo de TI y otros empleados, según sea necesario.

Controles de sistemas y organizaciones (SOC tipo 1, SOC tipo 2)

Si	No	Mejores Prácticas(.)	Observaciones(*)
		(.) Se establecen políticas de acceso de usuarios. * Mínimo privilegio y separación de funciones no están implementadas.	
		(.) Los datos sensibles (PII/SPII) son confidenciales/privados. * La encriptación está desactivada lo que pone en peligro la confidencialidad de la información PII/SPII.	
		(.) La integridad de los datos garantiza que estos sean consistentes, completos, precisos y hayan sido validados. * La integridad no está del todo garantizada ya que todos los empleados pueden acceder a la data modificarla o verla.	
		(.) Los datos están disponibles para las personas autorizadas a acceder a ellos. * Mientras la información esté disponible para todos los empleados, se necesita limitar la autorización de archivos solo a personas que necesiten de esa información para poder realizar su trabajo.	

RECOMENDACION:

- 1) Para una mayor seguridad en una autenticación de empleados se recomienda el uso de MFA (Verificación de Múltiples factores).**
- 2) Realice periódicamente pruebas de penetración para encontrar vulnerabilidades en su sistema y/o red.**

